

Tuần 4 — API Gateway + S3 (góc nhìn Developer)

Domain: Domain 1 – Development (32%) · **Thời lượng:** ~11h (4 buổi) · **Vị trí:** Tuần 4/5 của Domain 1

Điều hướng: [← Tuần 3](#) · [🏠 Kế hoạch tổng](#) · [Tuần 5 →](#)

Mục tiêu tuần này

- Tự tay dựng được **REST API** → **Lambda** → **DynamoDB** với CRUD đầy đủ (POST/GET/PUT/DELETE).
- Giải thích được sự khác biệt **REST API** vs **HTTP API** vs **WebSocket API** và chọn đúng loại theo yêu cầu đề.
- Phân biệt được **Lambda proxy (AWS_PROXY)** vs non-proxy và biết khi nào cần mapping template **VTL**.
- Cấu hình được 4 loại authorizer: **IAM (SigV4)**, **Cognito User Pool**, **Lambda authorizer TOKEN** và **REQUEST**.
- Tạo được **presigned URL** cho cả PUT (upload) lẫn GET (download) và giải thích được quyền của URL đó kế thừa từ đâu.
- Thực hiện được **multipart upload** qua CLI và cấu hình **S3 event notification** bắn tới **Lambda**.

Nội dung học chi tiết

Buổi A — Lý thuyết (~3h)

1. Ba loại API — chọn cái nào?

Loại	Dùng khi	Điểm mạnh
REST API	Cần đầy đủ tính năng doanh nghiệp	API keys + usage plans , mapping request/response VTL , caching , tích hợp WAF , Private API

Loại	Dùng khi	Điểm mạnh
HTTP API	Proxy đơn giản tới Lambda/HTTP	Rẻ hơn, độ trễ thấp hơn, hỗ trợ JWT authorizer/OIDC — nhưng ít tính năng hơn REST
WebSocket API	Real-time hai chiều (chat, dashboard live)	Kết nối bền, server đẩy dữ liệu về client

Neo thi: Đề hỏi "rẻ nhất / độ trễ thấp nhất cho proxy tới Lambda" → **HTTP API**. Đề nhắc **API keys, usage plans, caching**, mapping **VTL, WAF, Private API** → phải là **REST API**. Đề nhắc "đẩy dữ liệu real-time hai chiều" → **WebSocket API**.

2. Integration types (kiểu tích hợp backend)

- **Lambda proxy (AWS_PROXY)**: truyền **nguyên** request (headers, query, path, body) vào **Lambda** dưới dạng event chuẩn; **Lambda tự chịu trách nhiệm** trả về đúng format **{ statusCode, headers, body }**. Ít cấu hình nhất, phổ biến nhất.
- **Lambda (non-proxy)**: dùng **mapping template VTL** để biến đổi request trước khi vào backend và biến đổi response trước khi trả client. Kiểm soát chi tiết nhưng phức tạp.
- **HTTP / HTTP proxy**: gọi tới một HTTP endpoint bất kỳ.
- **AWS service**: gọi thẳng dịch vụ AWS (vd đẩy message vào **SQS**, ghi **DynamoDB**) không cần **Lambda** trung gian.
- **Mock**: trả response tĩnh, không gọi backend — hữu ích test / trả CORS preflight.

3. Mapping templates (VTL) & Gateway Responses

- Mapping template dùng ngôn ngữ **VTL** (Velocity) để nhào nặn payload — chỉ có ở non-proxy integration.
- **Gateway Responses**: tùy biến response khi lỗi xảy ra **ở tầng gateway** (vd 401 do authorizer, 429 do throttling) trước khi tới backend.

4. Stages + stage variables

- **Stage** = một bản deploy có tên (vd **dev, prod**), mỗi stage có URL riêng.
- **Stage variables** = cặp key-value theo stage, hoạt động như biến môi trường. Kinh điển: trỏ tới **Lambda alias** khác nhau theo stage (vd **\${stageVariables.lambdaAlias}** → stage **prod** gọi alias **PROD**, stage **dev** gọi alias **DEV**) — cùng một API definition, backend khác nhau.

5. Authorizers (xác thực/ủy quyền)

Authorizer	Cơ chế	Ghi chú
IAM	Ký SigV4 bằng credential AWS	Dùng cho service-to-service, người dùng có IAM cred
Cognito User Pool	Kiểm JWT do User Pool cấp	Người dùng đăng nhập app
Lambda authorizer — TOKEN	Nhận 1 token ở header (vd Authorization)	Trả về IAM policy Allow/Deny
Lambda authorizer — REQUEST	Xét nhiều tham số request (headers, query, path, context)	Linh hoạt hơn TOKEN

6. Usage plans, API keys, throttling, caching, CORS

- **API keys + usage plans**: giới hạn/định lượng lượng gọi theo từng khách hàng (chỉ **REST API**).
- Throttling mặc định mức account: **10.000 request/giây**, burst **5.000**.
- **Caching**: bật **theo stage**, giảm tải backend, TTL mặc định **300 giây** (chỉnh trong khoảng 0–3600s). Chỉ **REST API**.
- **Integration timeout mặc định 29s**; có thể **tăng tới 300s** qua **Service Quotas** cho **Regional/private REST API** (KHÔNG áp dụng cho edge-optimized **REST API** & **HTTP API**; đánh đổi là giảm throttle quota). Tác vụ chạy dài vẫn nên xử lý **async** (trả 202 + chạy nền).
- **CORS**: phải cấu hình khi trình duyệt gọi API từ domain khác; preflight **OPTIONS** thường xử lý bằng Mock integration.

B Buổi B — Hands-on (~3.5h): **REST API** → **Lambda** → **DynamoDB (CRUD)**

 Lab cầm tay chỉ việc (từng bước + lệnh + code): labs.md.

1. Tạo bảng **DynamoDB** tên **Items** (partition key **id** kiểu String).
2. Viết 1 hàm **Lambda** xử lý CRUD, đọc **event.httpMethod** (proxy) để phân nhánh POST/GET/PUT/DELETE ghi/đọc **DynamoDB**. Trả về đúng **{ statusCode,**

`headers, body }`.

3. Tạo **REST API**, resource `/items` và `/items/{id}`.
4. Với mỗi method, tạo integration **Lambda proxy (AWS_PROXY)** trỏ tới hàm trên.
5. **Deploy** lên stage **dev**. Gọi thử bằng **curl** → xác nhận CRUD chạy.
6. Tạo **Lambda alias DEV** và **PROD**. Thêm **stage variable** `lambdaAlias` cho mỗi stage; sửa integration dùng `${stageVariables.lambdaAlias}` để mỗi stage gọi đúng alias.

```
# Gọi thử API sau khi deploy stage dev
curl -X POST https://<api-id>.execute-api.<region>.amazonaws.com/dev/items \
  -H "Content-Type: application/json" \
  -d '{"id":"1","name":"demo"}'

curl https://<api-id>.execute-api.<region>.amazonaws.com/dev/items/1
```

7. **Bật CORS** cho resource `/items` (Console: Enable CORS → tự sinh method **OPTIONS** bằng Mock).
8. **Gắn Lambda authorizer (TOKEN)**: viết hàm authorizer đọc header **Authorization**, trả IAM policy Allow/Deny; gán vào method rồi test với token hợp lệ/không hợp lệ.
9. **Gắn Cognito authorizer**: tạo **Cognito User Pool** + app client, tạo authorizer loại Cognito, gọi API kèm **IdToken** (JWT) trong header.

Buổi C — Bổ sung (~2.5h): **S3** cho Developer

1. **CRUD object**: **PutObject** / **GetObject** / **DeleteObject** / **ListObjectsV2** qua CLI.
2. **presigned URL** — sinh URL tạm có hạn cho cả upload (PUT) và download (GET). Hạn (**SigV4**): tối đa **7 ngày**; sinh qua Console chỉ tối đa **12 giờ**; nếu ký bằng **temp credentials** (**STS/role**) thì URL hết hạn theo credential đó (dù đặt expiry dài hơn).

```
# Presigned GET (download) — hết hạn sau 300 giây
aws s3 presign s3://my-bucket/report.pdf --expires-in 300

# Presigned PUT (upload) — cần chỉ định method PUT
aws s3 presign ... # hoặc dùng SDK: s3.generate_presigned_url('put_object',
...)
```

3. **multipart upload**: chia object lớn thành nhiều part, upload song song, ghép lại; hỗ trợ **byte-range fetch** khi tải xuống (tải một khúc bằng header **Range**).

```
# CLI cấp cao tự động dùng multipart khi file lớn
aws s3 cp big-file.bin s3://my-bucket/big-file.bin
```

4. **Encryption** — năm 4 kiểu:

Kiểu	Ai giữ khoá	Ghi chú thi
SSE-S3	AWS quản lý (AES-256)	Mặc định TỰ ĐỘNG cho MỌI object mới từ 01/2023 (không cần bật); đơn giản, không audit theo khoá
SSE-KMS	Khoá KMS	Có audit (CloudTrail) + rotation ; kiểm soát quyền dùng khoá
SSE-C	Khách tự cung cấp khoá mỗi request	AWS không lưu khoá
Client-side	Khách mã hoá trước khi upload	AWS chỉ thấy ciphertext

5. **Versioning + event notifications**: bật versioning; cấu hình **S3 event notification** (vd **s3:ObjectCreated:***) bắn tới **Lambda** (đích khác có thể là **SQS / SNS / EventBridge**). Test bằng cách upload file và xem **Lambda** được kích hoạt.

6. Ghi nhớ: **S3** hiện có **strong read-after-write consistency** cho mọi thao tác — không còn lo "đọc ngay sau ghi bị dữ liệu cũ".

7. **CloudFront** — phân phối nội dung private (góc Developer)

- **Signed URL** vs **Signed cookies** (cả hai ký bằng **trusted key group**):
 - **Signed URL**: cấp quyền cho **1 file**; hợp khi client **không hỗ trợ cookie** (vd app RTMP cũ, tải file lẻ).
 - **Signed cookies**: cấp quyền cho **nhiều file** cùng lúc mà **giữ nguyên URL gốc** (vd cả thư mục media, streaming HLS).
- **S3 presigned URL** vs **CloudFront signed URL** (dễ lẫn):
 - **S3 presigned URL**: truy cập **thẳng vào S3**, kế thừa **quyền IAM của identity đã tạo**, thường cho **1 object**, dùng cho upload/download tạm.

- **CloudFront** signed URL: truy cập **qua edge/cache** (nhANH, gần user), ký bằng **key pair / trusted key group**, hợp phân phối nội dung **private toàn cầu** ở quy mô lớn.
- **OAC (Origin Access Control)** thay cho **OAI** (đời cũ): khoá bucket **S3 chỉ cho CloudFront đọc** (bucket policy chỉ allow OAC), người dùng không truy cập **S3** trực tiếp được. **OAC** là khuyến nghị hiện tại (hỗ trợ **SSE-KMS**, mọi region).
- **Cache invalidation**: đẩy nội dung mới trước TTL bằng **CreateInvalidation** (theo path; **1000 path/tháng đầu miễn phí**, sau đó tính phí) — hoặc tốt hơn là dùng **versioned object name** (đổi tên file, vd **app.v2.js**) để không cần invalidate.

8. **AppSync** — managed GraphQL (thay/bổ trợ **REST**)

- Một **endpoint GraphQL** duy nhất; client **chọn đúng field cần** (giảm over-/under-fetch).
- **Resolver** (viết bằng **VTL** hoặc JS) nối tới data source: **DynamoDB / Lambda / HTTP endpoint**.
- **Subscription** real-time qua **WebSocket** (đẩy dữ liệu về client khi có thay đổi).
- AuthZ tích hợp sẵn: **Cognito User Pool / IAM / API key / Lambda authorizer** (OIDC).
- **Đối chiếu**: cần REST truyền thống → **API Gateway** (REST/HTTP API); client cần **query linh hoạt / real-time** → **AppSync** (GraphQL).

D Buổi D — Practice + Review (~2h)

 **Bộ câu hỏi luyện tập của tuần:** [questions.md](#) — đáp án & giải thích: [answers.md](#). (bằng tiếng Anh — văn phong đề thật để làm quen đề.)

- Làm 30–40 câu practice tập trung **API Gateway + S3**.
- Ghi mọi câu sai vào sổ lỗi: ghi rõ **keyword đề** → **đáp án đúng** → **lý do**.
- Ôn spaced repetition: xem lại flashcard tuần này ở mốc **1 / 3 / 7 ngày**; đảo lại số liệu ở mục "PHẢI NHỚ".
- Tự trả lời toàn bộ "Công tự kiểm tra" bên dưới, không nhìn đáp án.

 **PHẢI NHỚ tuần này**

Fact	Số / Giá trị
Integration timeout của API Gateway	Mặc định 29s ; tăng tới 300s qua Service Quotas (chỉ Regional/private REST API)
Throttling mặc định mức account	10.000 req/giây , burst 5.000
Caching bật theo	Stage , TTL mặc định 300 giây (0–3600s)
S3 object tối đa	5 TB
Single PutObject tối đa	5 GB
multipart upload KHUYẾN NGHỊ khi	object** > 100 MB**
multipart upload BẮT BUỘC khi	object** > 5 GB**
presigned URL kế thừa quyền của	identity đã tạo ra nó ; hạn SigV4 tối đa 7 ngày (Console 12h ; temp credentials → hết hạn theo credential)
API keys + usage plans chỉ có ở	REST API (không có ở HTTP API)
S3 consistency	strong read-after-write cho mọi thao tác
Đích S3 event notification	Lambda / SQS / SNS / EventBridge

⚠ Bẫy đề hay gặp

- Thấy "proxy đơn giản tới **Lambda**, rẻ nhất, độ trễ thấp" → dễ chọn **REST API**, nhưng đúng là **HTTP API**.
- Thấy "cần **API keys / usage plans / caching / mapping VTL / WAF**" → **HTTP API KHÔNG** có những thứ này → phải là **REST API**.
- Thấy "backend chạy 45 giây rồi API trả lỗi" → timeout **mặc định 29s** (có thể tăng tới **300s** qua **Service Quotas** chỉ cho Regional/private **REST API**, đổi lại giảm throttle quota); tác vụ dài vẫn nên async (trả 202 + xử lý nền).
- Thấy "**Lambda proxy** mà response sai/lỗi 502" → thường do **Lambda không trả đúng format {statusCode, headers, body}** — bản chất proxy đẩy quyền

format cho **Lambda**.

- Thấy "cho phép người ngoài upload file trực tiếp lên **S3** mà không lộ credential" → **presigned URL (PUT)**, KHÔNG phát AWS key.
- Thấy "cần audit ai dùng khoá + tự rotate khoá" → **SSE-KMS**, không phải **SSE-S3**.
- Thấy "khách muốn tự giữ khoá mã hoá, AWS không được lưu" → **SSE-C** (hoặc client-side), không phải **SSE-KMS**.
- Thấy "xác thực bằng JWT từ user đăng nhập app" → **Cognito User Pool authorizer**; còn xác thực bằng credential AWS ký request → **IAM (SigV4)**.



Phản xạ nhanh (keyword → đáp án)

Thấy từ khoá	Bật ngay
Rẻ nhất / độ trễ thấp / proxy Lambda	HTTP API
API keys , usage plans , caching , VTL , WAF , Private API	REST API
Real-time hai chiều, server đẩy về client	WebSocket API
Biến đổi request/response, template	Non-proxy + mapping VTL
Truyền nguyên request, Lambda tự format	Lambda proxy (AWS_PROXY)
Trở backend khác nhau theo môi trường	Stage variables → Lambda alias
Cho phép upload/download tạm, không lộ key	presigned URL
Xác thực JWT người dùng app	Cognito User Pool authorizer
Xác thực bằng cred AWS (SigV4)	IAM authorizer
Logic uỷ quyền tùy biến theo token	Lambda authorizer (TOKEN/REQUEST)
Object > 5 GB	Bắt buộc multipart upload
Cần audit + rotate khoá mã hoá	SSE-KMS
Khách tự cung cấp khoá	SSE-C
File mới vào bucket → chạy code	S3 event notification → Lambda

Thấy từ khoá	Bật ngay
Phân phối hiều file private qua CDN	CloudFront signed cookies
1 file private có hạn	CloudFront signed URL / S3 presigned URL
Khoá bucket S3 chỉ cho CloudFront đọc	OAC (thay OAI)
Client cần query linh hoạt / real-time	AppSync (GraphQL)



Lab checklist

- ☐ Dựng **REST API** → **Lambda** → **DynamoDB** CRUD đủ POST/GET/PUT/DELETE
- ☐ Deploy 2 stage (**dev/prod**) + stage variable trỏ **Lambda alias**
- ☐ Bật CORS cho resource
- ☐ Gắn và test **Lambda authorizer** (TOKEN)
- ☐ Gắn và test **Cognito User Pool authorizer**
- ☐ Tạo **presigned URL** PUT và GET, test upload/download
- ☐ Thực hiện **multipart upload** qua CLI cho file lớn
- ☐ Cấu hình **S3 event notification** → **Lambda** và xác nhận trigger

Cổng tự kiểm tra (phải trả lời trôi chảy mới sang tuần sau)

- REST API** vs **HTTP API** khác gì và chọn khi nào? **Đáp án gọn:** **HTTP API** rẻ hơn, độ trễ thấp hơn, hợp proxy tới **Lambda/HTTP**, hỗ trợ **JWT/OIDC** — nhưng **THIẾU API keys/usage plans**, mapping **VTL**, **caching**, **WAF**, **Private API**. Cần các thứ đó → chọn **REST API**.
- presigned URL** kế thừa quyền của ai? **Đáp án gọn:** Của **identity đã tạo ra URL** đó; ai cầm cũng dùng được trong quyền đó cho tới khi hết hạn. Hạn **SigV4** tối đa **7 ngày** (Console **12h**); nếu ký bằng temp credentials thì hết hạn theo credential.
- multipart upload** bắt buộc khi object lớn hơn bao nhiêu? **Đáp án gọn:** **Bắt buộc khi > 5 GB** (single PUT tối đa 5 GB); **khuyến nghị khi > 100 MB**. Object tối đa 5 TB.
- Proxy vs non-proxy integration khác gì? **Đáp án gọn:** **Lambda proxy** (**AWS_PROXY**) truyền nguyên request, **Lambda** tự trả đúng **{statusCode,**

headers, body}. Non-proxy dùng mapping template **VTL** biến đổi request/response.

5. Integration timeout của **API Gateway** là bao nhiêu? **Đáp án gọn: Mặc định 29s**; có thể **tăng tới 300s** qua **Service Quotas** cho **Regional/private REST API** (KHÔNG áp dụng edge-optimized **REST API** & **HTTP API**; đánh đổi là giảm throttle quota). Tác vụ dài vẫn nên xử lý **async**.
6. Khi nào dùng **SSE-KMS** thay vì **SSE-S3**? **Đáp án gọn:** Khi cần **audit** (log qua **CloudTrail**), **rotation** và kiểm soát quyền dùng khoá; **SSE-S3** chỉ là AES-256 do AWS quản lý, không audit theo khoá.

Tài nguyên tuần này

 **Đã crawl sẵn tài liệu AWS vào [resources/](#)** — đọc offline được.

- AWS Docs: **API Gateway** Developer Guide — REST vs HTTP API, Stages & stage variables, Integration types, Mapping templates (**VTL**), Authorizers, Usage plans & API keys, Caching, CORS.
- AWS Docs: **Amazon S3** User Guide — Presigned URLs, Multipart upload, Byte-range fetch, Server-side encryption (**SSE-S3/SSE-KMS/SSE-C**), Versioning, Event notifications.
- AWS FAQ: **Amazon API Gateway** FAQs; **Amazon S3** FAQs (mục consistency, encryption).
- Khoá Stephane Maarek / Adrian Cantrill: section **API Gateway** và section **S3** (phần dành cho Developer).

Checklist hoàn thành Tuần 4

- ☐ Hoàn thành 4 buổi A/B/C/D
- ☐ Nắm 3 loại API và tiêu chí chọn
- ☐ Phân biệt proxy vs non-proxy + biết mapping **VTL**
- ☐ Cấu hình được cả 4 loại authorizer
- ☐ Thành thạo **presigned URL**, **multipart upload**, encryption **S3**
- ☐ Hoàn thành Lab checklist
- ☐ Thuộc bảng "PHẢI NHỚ" (số liệu chính xác)
- ☐ Vượt Cổng tự kiểm tra